

secanalyzer

AI-assisted local security CLI

Siddhu Bhimireddy · CSC 366 · Final Release

github.com/flufcloud/366_project

The Problem

Modern codebases are large and hard to understand (especially to newcomers).

Manual security review is arudous

What Teams Struggle With

Understanding architecture

- New security engineers do not fully understand the architecture of the codebase (eg trust boundaries)
- Simple maps of codebases with a security focus are not easily accessible

Triaging GitHub work

- Dozens of open PRs and issues
- Not clear which are the most important for security purposes

Developer tooling

- Developers are already using AI
- But orgs do not have security focused wrappers/harnesses for AI-powered analyzers

Avoiding secret leakage

- Copy-pasting code into AI tools is risky
- Tokens and API keys can end up in prompts

secanalyzer

A local CLI that scans your codebase, triages GitHub issues and PRs with risk labels, and generates security summaries.

Architecture

```
User → CLI (secanalyzer)
    ├── Local filesystem → Markdown output
    ├── GitHub REST API  → Issues / PR triage
    └── LLM Vendor API    → AI narratives
        (Anthropic Claude or Google Gemini)
```

Deployment model: single-user Python 3.11+ CLI, installed via `pip`. I recommend you use `uv` to manage projects and packages!

Trust boundary: your laptop and local credential files. Everything else is external.

Key Features

Codebase Docs

```
secanalyzer --scan PATH
```

Recursively walk through a codebase -> Markdown of file inventory, sizes, redaction warnings, and snippets

Add `--llm-report` for deep per-file AI security review and overarching summary.

Issue & PR Analyzer

```
secanalyzer --issues owner/repo
```

Fetches open issues and PRs via GitHub PAT. These issues can then be individually analyzed with AI. Option to provide analyzer security analysis of codebase for better outputs

Mitigations

Each analyzed item returns:

- **Risk level** (low / medium / high)
- **Justification**
- **Code locations** (path + line range)
- **Suggested mitigation**

Six Core Components

Component	Module	Responsibility
A1 CLI Interface	<code>cli.py</code>	argparse; user-facing error messages; exit codes
A2 ConfigManager	<code>config.py</code>	GitHub PAT + LLM keys in user config dir
A3 RepositoryAnalyzer	<code>repo_analyzer.py</code>	Regex redaction, adjustable caps on tokens
A4 GitHub API Client	<code>github_client.py</code>	List of issues/PRs per repo, analyze individual issues
A5 LLM Orchestration	<code>llm.py</code> / <code>scan_llm.py</code>	Prompt building, token budgets, API tokens, retries
A6 Output & Session	<code>output.py</code> / <code>issues_session.py</code>	file output write; terminal output

Security Overview: Three Most Important Threats

Threat	What We Do	Risks
Prompt injection via issue/PR text	Delimiter blocks; JSON schema validation on responses	LLMs can still be biased; not cryptographically enforceable
Credential leakage to logs or prompts	<code>getpass</code> ; keys in HTTP headers only; pre-send regex aborts call if secrets detected	Compromised host reads config files; regex is static
Supply chain attacks	<code>uv.lock</code> pinned; CI runs <code>uv sync --frozen</code> + <code>bandit</code> + <code>pip-audit</code>	Lockfile tampering in PR; zero-days in deps

What Data Leaves the Machine

✓ Never Sent

- Raw GitHub token or LLM API key in prompt bodies
- Full repository as a single dump (default modes)
- Binary files or files outside extension allowlist

⚠ May Be Sent (LLM features, user opt-in)

- Truncated + redacted file snippets
(`--llm-report`)
- GitHub issue/PR title, body, truncated patch hunks
- Rolling summaries from prior analysis
(compaction/synthesis)

See `SECURITY.md` in repo for full data-handling policy.

Demo Context — openwearables

the-momentum/open-wearables

open-wearables

CodeIssues 132Pull requests 19AgentsDiscussionsActionsProjectsSecurity and qualityInsights

open-wearablesPublic

Watch 19Fork 279Star 1.7k

main33 Branches13 Tags

Go to fileAdd fileCode

czajkubfix: Cast to local date for summary endpoints (#1033)4 days ago557 Commits

ai	chore: add top-level imports rule to code review skill and bac...	3 months ago
cursor/rules	feat(vibes): Add rules config for most popular Code Agents (#...	5 months ago
gemin	feat(vibes): Add rules config for most popular Code Agents (#...	5 months ago
github	Revert "feat: introduce AI health reasoning agent service (#90...	last month
.vscode	Revert "feat: introduce AI health reasoning agent service (#90...	last month
backend	fix: Cast to local date for summary endpoints (#1033)	4 days ago
contributing	feat: Suunto webhooks + provider capabilities reworked (#942)	last month
docs	feat(backend): add recovery summary endpoint (#1027)	last week
frontend	refactor(frontend): updated all TypeScript dependencies (#10...	last week
mcp	feat(mcp): add get_timeseries tool for granular sample querie...	last month
aider.md	feat(vibes): Add rules config for most popular Code Agents (#...	5 months ago
.coderabbit.yaml	chore: add CodeRabbit check for data migration impact on p...	last month
gitignore	Revert "feat: introduce AI health reasoning agent service (#90...	last month
pre-commit-config.yaml	Revert "feat: introduce AI health reasoning agent service (#90...	last month

About

Self-hosted platform to unify wearable health data through one AI-ready API.

docs.openwearables.io

python, gemini, quantified-self, fitness, health, self-hosted, healthcare, apple-watch, suunto, wearables, apple-health, fitness-api, fastapi, healthcare-ai, fitness-analysis

Readme, MIT license, Contributing, Activity, Custom properties, 1.7k stars, 19 watching, 279 forks, Report repository

Releases 130.5.1 - Oura & Strava Webho...last week17 releases

Open WearablesPlatformUse CasesEnterpriseIntegrationsPricingDocs0.5.1Book a DemoGet Started

Join our Discord

OPEN SOURCE · SELF-HOSTED · MIT LICENSE

Health intelligence, not just health data.

Turn wearable data into health scores and AI recommendations your users can act on.

Self-hosted on your infrastructure. Your data, your compliance, your control.

Get StartedBook a Demo

Home, Sources, Samsung Health, Google Health Connect, Uthmaniyah, Fitbit, Apple Health, Strava, Polar, Suunto, Samsung Health, Google Health Connect, Uthmaniyah, Fitbit, Apple Health, Strava, Polar, Suunto

Demo · CLI Overview

```
secanalyzer --help
```

A quick orientation to all available commands before the demo proper.

Demo · List models

```
# List all available Google models  
secanalyzer --list-google-models
```

```
# Pin a model for this session  
export SECANALYZER_GEMINI_MODEL=gemini-  
2.0-flash
```

Shows available models and lets you pin a specific model id before running any LLM-backed commands

Demo · Static Scan

Full report output

~60 seconds run time for medium sized
codebase

No LLM, no network. File inventory, redaction
warnings, safe to run anywhere.

Demo · Issue Triage

secanalyzer --list-issues the-momentum/open-wearables

Lists all the available issues (alternatively you can just go to the Github page of course)

```
siddhu@siddhu: /mnt/c/Users/Sidd/Desktop/academic/366/366_project$ uv run secanalyzer --list-issues the-momentum/open-wearables
# Open issues and pull requests - 'the-momentum/open-wearables'

**Total:** 151

# | Type | Title | Author | URL |
--|-----|-----|-----|-----|
847 | Issue | missing GPS routes | '@raabdesselam' | https://github.com/the-momentum/open-wearables/issues/847 |
991 | Issue | Add metrics related to womens health | '@anjazych' | https://github.com/the-momentum/open-wearables/issues/991 |
1045 | PR | fix(integrations): emit outgoing webhook for suunto live workout push | 'HugoHeneault' | https://github.com/the-momentum/open-wearables/pull/1045 |
1042 | PR | fix(integrations): handle Suunto workout webhook edge cases | 'HugoHeneault' | https://github.com/the-momentum/open-wearables/pull/1042 |
1043 | PR | feat(suunto): pause-aware stopTime + gear from SummaryExtension | 'HugoHeneault' | https://github.com/the-momentum/open-wearables/pull/1043 |
1041 | PR | feat: Polar refactor | 'czajkub' | https://github.com/the-momentum/open-wearables/pull/1041 |
1032 | PR | fix(users): skip invalid user rows during email validation | 'xjt242px-creator' | https://github.com/the-momentum/open-wearables/pull/1032 |
1047 | PR | fix: Handle duplicate EventRecordDetail inserts gracefully with savepoint | 'czajkub' | https://github.com/the-momentum/open-wearables/pull/1047 |
1048 | PR | fix: Add missing workout types, rename series type to SDK | 'czajkub' | https://github.com/the-momentum/open-wearables/pull/1048 |
1049 | PR | feat: Add webhook management endpoints | 'czajkub' | https://github.com/the-momentum/open-wearables/pull/1049 |
1034 | PR | chore: bump the npm-minor-patch group in /frontend with 11 updates | 'dependabot[bot]' | https://github.com/the-momentum/open-wearables/pull/1034 |
1035 | PR | chore: bump the python-minor-patch group across 1 directory with 5 updates | 'dependabot[bot]' | https://github.com/the-momentum/open-wearables/pull/1035 |
1036 | PR | chore: bump fastmcp from 2.14.2 to 3.2.3 in /mcp | 'dependabot[bot]' | https://github.com/the-momentum/open-wearables/pull/1036 |
1046 | Issue | Summaries are not summing correctly | 'shamanlola' | https://github.com/the-momentum/open-wearables/issues/1046 |
1009 | Issue | Provider Request: Google Health API (Fitbit successor) | 'rlarson7' | https://github.com/the-momentum/open-wearables/issues/1009 |
1031 | Issue | Historical sync orchestrator never commits the SQLAlchemy session - provider - | 'tristan531' | https://github.com/the-momentum/open-wearables/issues/1031 |
1030 | Issue | Oura: normalize sleeps() drops average_breath, respiratory_rate timeseries re. | 'tristan531' | https://github.com/the-momentum/open-wearables/issues/1030 |
1029 | Issue | Oura: save spo2_data() never commits - SpO2 and BDI samples silently dropped | 'tristan531' | https://github.com/the-momentum/open-wearables/issues/1029 |
1028 | Issue | Oura: sleep-summary endpoint hardcodes avg_respiratory_rate / avg_hrv_sdnr_ms. | 'tristan531' | https://github.com/the-momentum/open-wearables/issues/1028 |
791 | Issue | refactor: migrate Fitbit into using FitbitWebhookHandler | 'KaliszS' | https://github.com/the-momentum/open-wearables/issues/791 |
790 | Issue | refactor: migrate Polar into using PolarWebhookHandler | 'KaliszS' | https://github.com/the-momentum/open-wearables/issues/790 |
894 | PR | refactor(mcp): typed exception hierarchy + first test harness | 'kjsteuer' | https://github.com/the-momentum/open-wearables/pull/894 |
434 | Issue | Add developer applications management to frontend | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/434 |
663 | Issue | feat: consider adding series types for unmapped Ultrahuman metrics | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/663 |
664 | Issue | Add resting heart rate (night_rhr) parsing for Ultrahuman | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/664 |
665 | Issue | Parse and save granular sleep stages from Ultrahuman sleep_graph | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/665 |
682 | Issue | Implement deregistration for providers with Cloud API | 'czajkub' | https://github.com/the-momentum/open-wearables/issues/682 |
733 | Issue | Provider request: Komoot | 'slavrosin' | https://github.com/the-momentum/open-wearables/issues/733 |
788 | Issue | feat: follow historical sync status | 'KaliszS' | https://github.com/the-momentum/open-wearables/issues/788 |
862 | Issue | bug(users): get_users_paginated 500s the entire endpoint when any single user. | 'kjsteuer' | https://github.com/the-momentum/open-wearables/issues/862 |
983 | Issue | Sleep score: show source provider for OW (internal) scores on dashboard | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/983 |
1020 | Issue | Feature request: calorie intake and macronutrient counters | 'fuzzie369' | https://github.com/the-momentum/open-wearables/issues/1020 |
1013 | PR | fix(backend): prevent InvalidRequestError in after_commit webhook listeners | 'andy200lag-synaptik' | https://github.com/the-momentum/open-wearables/pull/1013 |
1006 | PR | fix: batch sleep-summary HR averages to resolve N+1 (#493) | 'SumaReddy369' | https://github.com/the-momentum/open-wearables/pull/1006 |
1011 | Issue | Add '/list' and '/renew' to incoming webhook endpoints | 'czajkub' | https://github.com/the-momentum/open-wearables/issues/1011 |
1009 | Issue | Duplicate sleep score / timestamp mismatch in Whoop | 'czajkub' | https://github.com/the-momentum/open-wearables/issues/1009 |
1008 | Issue | Cycle endpoint support for Whoop | 'czajkub' | https://github.com/the-momentum/open-wearables/issues/1008 |
1002 | Issue | Error while saving records | 'davidssand' | https://github.com/the-momentum/open-wearables/issues/1002 |
1001 | Issue | Provider Request: MapMyFitness / Under Armour (MapMyRun) | 'rlarson7' | https://github.com/the-momentum/open-wearables/issues/1001 |
999 | Issue | Provider request: Eight Sleep | 'vadini-agrawal' | https://github.com/the-momentum/open-wearables/issues/999 |
998 | Issue | Prompt Inject attempt detected in Agents.md | 'watermilan' | https://github.com/the-momentum/open-wearables/issues/998 |
997 | Issue | Provider request: Zepp / Amazfit | 'toast38coza' | https://github.com/the-momentum/open-wearables/issues/997 |
916 | Issue | Refactor: backend ingestion under apple/ actually serves all SDK providers | 'kjsteuer' | https://github.com/the-momentum/open-wearables/issues/916 |
893 | Issue | refactor(mcp): introduce typed exception hierarchy for client errors | 'kjsteuer' | https://github.com/the-momentum/open-wearables/issues/893 |
587 | Issue | Activity data (steps, calories, active minutes) missing for current/recent da. | 'hunden5' | https://github.com/the-momentum/open-wearables/issues/587 |
621 | Issue | feat: populate sleep stage timestamps for Whoop (parity with Apple Health) | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/621 |
857 | Issue | OW sleep score: inconsistencies in duration and stages components | 'anjazych' | https://github.com/the-momentum/open-wearables/issues/857 |
856 | Issue | Missing and incorrect sleep data from Oura | 'anjazych' | https://github.com/the-momentum/open-wearables/issues/856 |
735 | Issue | docs(aws-setup): missing S3 CORS config, Celery Worker AWS credentials, and S. | 'Brooky830' | https://github.com/the-momentum/open-wearables/issues/735 |
770 | Issue | Strava sync ignores date range - always fetches last 30 days | 'Brooky830' | https://github.com/the-momentum/open-wearables/issues/770 |
953 | Issue | feat(garmin): support FIT files for granular workout data | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/953 |
981 | Issue | docs: document max historical fetch range per provider | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/981 |
985 | PR | fix(backend): keep after_commit webhook listener safe across rollback | 'artursmolin' | https://github.com/the-momentum/open-wearables/pull/985 |
840 | Issue | feat: surface API errors with retry option across all user detail tabs | 'coderabbitai[bot]' | https://github.com/the-momentum/open-wearables/issues/840 |
801 | Issue | feat: Recovery Score by Open Wearables | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/801 |
980 | Issue | Provider request: MyMojoHealth (Keto-Mojo) - glucose & ketones | 'slavrosin' | https://github.com/the-momentum/open-wearables/issues/980 |
109 | Issue | Implement API calls in dashboard endpoint | 'KaliszS' | https://github.com/the-momentum/open-wearables/issues/109 |
576 | Issue | MCP server has no body/vitals tool | 'merksasar' | https://github.com/the-momentum/open-wearables/issues/576 |
575 | Issue | Body Metrics view only shows a fraction of stored body/vitals data | 'merksasar' | https://github.com/the-momentum/open-wearables/issues/575 |
635 | Issue | Refactor: move repository calls from routes to service layer | 'coderabbitai[bot]' | https://github.com/the-momentum/open-wearables/issues/635 |
698 | Issue | Samsung Galaxy Watch mapped as "other" instead of "watch" | 'bartmichalak' | https://github.com/the-momentum/open-wearables/issues/698 |
```

Demo · Issue Analysis Output

What the LLM returns after selecting an openwearables issue. You can send the output to a .md file if you would like.

```
siddhu@siddhu: /mnt/c/Users/Sidd/Desktop/academic/366/366_project$ uv run secanalyzer --analyze-issue the-momentum/open-wearables --issue-number 113
# Security overview - Issue #113

- **Repository:** `the-momentum/open-wearables`
- **Title:** OAuth flow fails for second user after completing first user's Polar authorization
- **URL:** https://github.com/the-momentum/open-wearables/issues/113
- **Author:** @bartmichalak
- **Comments included:** 0

## Risk level
Medium. An OAuth flow failure suggests issues with state management or session isolation, which could lead to more severe vulnerabilities if not properly addressed.

## Security overview
The reported issue describes a scenario where the Polar OAuth flow fails for a second user after a first user has successfully completed their authorization. This behavior points to a potential flaw in how the application manages state during the OAuth process, possibly indicating a lack of proper session isolation or the inadvertent use of shared state variables across different user authentications.

While the immediate impact appears to be a functional failure (preventing subsequent users from integrating Polar), such problems can sometimes be symptoms of deeper security weaknesses. Incorrect handling of session state, authorization tokens, or persistent data could, in more severe cases, lead to cross-user information leakage, authorization bypasses, or denial of service for legitimate users.

It is critical to ensure that each user's authorization attempt is entirely self-contained and does not leave residual state that interferes with other users or sessions. This principle is fundamental for maintaining the security and integrity of multi-user applications and their integrated services.

## Recommended actions
* Thoroughly investigate the application's state management throughout the Polar OAuth flow, paying close attention to how session data, tokens, and temporary states are handled.
* Verify that user sessions are properly isolated and that no global or shared state variables are inadvertently impacting subsequent authorization attempts by other users.
* Ensure that all sensitive data, such as OAuth tokens and state parameters, are strictly associated with the specific user's session and are not persisting or being overwritten across different user flows.
* Analyze the provided video (if accessible) to identify the exact point of failure and any error messages, which can provide critical insights into the underlying cause.
siddhu@siddhu: /mnt/c/Users/Sidd/Desktop/academic/366/366_project$
```

Demo · Issue Analysis Output w/ Context

With context

```
[WARNING] Using compaction/final-rolling-summary.md.
# Security overview - Issue #113

- **Repository:** 'the-momentum/open-wearables'
- **Title:** OAuth flow fails for second user after completing first user's Polar authorization
- **URL:** https://github.com/the-momentum/open-wearables/issues/113
- **Author:** @bartmichalak
- **Comments included:** 0

## Risk level
Medium. While this issue currently manifests as a functional failure preventing a second user's authorization, it points to potential underlying problems with state management, session handling, or token storage within the critical OAuth flow for a platform processing sensitive Personal Health Information (PHI).

## Security overview
The reported issue describes a failure in the Polar OAuth authorization flow when a second user attempts to connect after a first user has successfully completed the process. While the current manifestation is a denial of service for the second user (preventing them from connecting their account), which paradoxically prevents potential unauthorized data access, the root cause is critical. An improperly implemented or failing OAuth flow can indicate fundamental flaws in how the application manages user sessions, cryptographic states, or token storage.

The codebase context highlights that the Open Wearables platform processes highly sensitive PHI through internet-facing APIs. Robust authentication and authorization mechanisms are paramount to protect this data. A failure in the OAuth process, even if preventing access, requires thorough investigation to ensure it's not a symptom of broader vulnerabilities such as session fixation, cross-site request forgery (CSRF) if state parameters are mishandled, or incorrect user context separation that could be exploited in different scenarios.

Given the platform's distributed architecture and the critical nature of PHI, ensuring that each user's authorization process is entirely isolated and correctly managed is essential. Any confusion in user sessions or persistence of state from a previous authorization attempt across different users could potentially lead to serious security implications if the failure mechanism were to behave differently under other circumstances or if state information were leaked.

## Recommended actions
* **Investigate Root Cause:** Thoroughly debug and identify the exact reason for the OAuth flow failure for subsequent users.
* **Review OAuth State Management:** Verify how 'state' parameters are generated, stored, and validated during the OAuth callback. Ensure they are unique per user and per authorization attempt to prevent CSRF and session fixation.
* **Examine Session and Token Handling:** Review how user sessions are managed and how authorization tokens (temporary or permanent) are stored and retrieved, ensuring strict isolation between different users. Check for any caching or shared state that might incorrectly persist from one user's authorization to another's.
* **Add Detailed Logging:** Implement comprehensive logging for all stages of the OAuth authorization flow, including redirects, token exchanges, and error conditions, to aid in diagnosis and future incident response.
```


When Models Echo the Prompt

What happened

Running an `llm-report` with a low-capacity Gemma model on some code produced the **prompt** instead of a risk analysis

Why it happens

- Small Gemma variants are not very good at instruction-following
- Small models tend to also be bad at outputting **diverse** text in structured format

Mitigation

- Use a stronger model
- **Gemini 1.5 / 2.0 Flash** via `SECANALYZER_GEMINI_MODEL`
- Gemma is probably just too weak. For other variants, you might try the Llama family.

Model Echoes

```
# LLM security report

- **Repository:** `~/mnt/c/Users/Sidd/Desktop/academic/projects/challenge`
- **Generated (UTC):** 2026-05-18 20:38:50Z
- **Files analyzed by LLM:** 2 / 3 indexed
- **High/medium attack-surface files highlighted:** 2

## Executive summary`.
* Required sections (in order):
  1. `## Executive summary`
  2. `## Architecture and trust boundaries`
  3. `## High attack-surface files`
  4. `## Broader codebase themes`
  5. `## Recommended review checklist`
* Constraint: No outlines, plans, meta-commentary, or code fences.
* Word count: ~800-2,000 words.
* Base: Rolling summary and file notes provided.

* `part1.py`: Local preprocessing script. Splits `train.txt` into train/dev sets.
  * Issues: Hardcoded path (`~/home/bhbmics/Documents/challenge-data`), `NameError` because logic for `train` and `dev` variables is commented out.
  * Risk: Very low. No network, no user input.
* `pyproject.toml`: Basic config.
  * Issues: None. Empty dependencies.
  * Architecture: Local filesystem utility. No external interfaces.

* "Executive Summary": The codebase consists of a small set of local utility files for data preprocessing. The overall security risk is negligible as there are no network interfaces or user-controllable inputs. However, the primary functional script is broken due to commented-out logic and is non-portable due to hardcoded absolute paths.

|
* "Architecture and Trust Boundaries": The architecture is a simple linear data pipeline: Read local file -> Process/Split -> Write local files. The trust boundary is limited to the local filesystem of the machine running the script. There is no authentication, authorization, or network-facing component. The script assumes the execution environment has a specific directory structure and that the input file `train.txt` exists in the working directory.

* "High Attack-Surface Files":
  * `part1.py`: This is the only file with executable logic. While the attack surface is low, it represents the primary point of failure. It reads binary/text data from a local file and writes to a hardcoded directory. The use of `with` statements for file handling is a positive pattern.
  * `pyproject.toml`: Pure configuration. No risk.

* "Broader Codebase Themes":
  * "Environment Leakage": The use of `~/home/bhbmics/...` suggests a lack of environment abstraction, leaking information about the developer's local setup.
  * "Code Quality": The presence of commented-out critical logic (`train` and `dev` variables) suggests the codebase is in an unfinished or experimental state.
  * "Portability": Lack of relative pathing or configuration-driven paths makes the utility non-portable.

* "Recommended Review Checklist":
  1. Fix `NameError` by uncommenting or implementing the splitting logic.
  2. Replace hardcoded absolute paths with relative paths or environment variables.
  3. Validate the existence and format of `train.txt` before processing.
  4. Confirm if any external dependencies should be added to `pyproject.toml`.

* Ensure prose is complete and detailed.
* Avoid meta-commentary.
* Stick to the provided data.
* Check word count (expand where possible by discussing the implications of the findings).

* "Self-Correction during drafting": The input is very small (only 2-3 files). Reaching 800 words will require detailed analysis of the implications of the found issues (e.g., discussing why hardcoded paths are a security/operational risk, explaining the `NameError` in detail, and expanding on the lack of input validation for `train.txt`).
```

Demo · Running the Report

```
secanalyzer --llm-report [path-to-dir]
```

- This takes a long time to run...
 - Also note that you need to pull the repo onto your device before you can analyze it
-

Report Endscren

```
[681/730] Analyzing frontend/src/router.tsx ...
[682/730] Analyzing frontend/src/routes/_root.tsx ...
[683/730] Analyzing frontend/src/routes/_authenticated.tsx ...
[684/730] Analyzing frontend/src/routes/_authenticated/dashboard.tsx ...
[685/730] Analyzing frontend/src/routes/_authenticated/settings.tsx ...
[686/730] Analyzing frontend/src/routes/_authenticated/settings/-credentials-tab.tsx ...
[687/730] Analyzing frontend/src/routes/_authenticated/settings/-data-lifecycle-tab.tsx ...
[688/730] Analyzing frontend/src/routes/_authenticated/settings/-priorities-tab.tsx ...
Compacting rolling context after 688 file(s) ...
[689/730] Analyzing frontend/src/routes/_authenticated/settings/-providers-tab.tsx ...
[690/730] Analyzing frontend/src/routes/_authenticated/settings/-security-tab.tsx ...
[691/730] Analyzing frontend/src/routes/_authenticated/settings/-seed-data-tab.tsx ...
[692/730] Analyzing frontend/src/routes/_authenticated/settings/-team-tab.tsx ...
[693/730] Analyzing frontend/src/routes/_authenticated/syncs.tsx ...
[694/730] Analyzing frontend/src/routes/_authenticated/syncs/index.tsx ...
[695/730] Analyzing frontend/src/routes/_authenticated/users.tsx ...
[696/730] Analyzing frontend/src/routes/_authenticated/users/$userId.tsx ...
Compacting rolling context after 696 file(s) ...
[697/730] Analyzing frontend/src/routes/_authenticated/users/index.tsx ...
[698/730] Analyzing frontend/src/routes/_authenticated/webhooks.tsx ...
[699/730] Analyzing frontend/src/routes/_authenticated/webhooks/$endpointId.tsx ...
[700/730] Analyzing frontend/src/routes/_authenticated/webhooks/index.tsx ...
[701/730] Analyzing frontend/src/routes/accept-invite.tsx ...
[702/730] Analyzing frontend/src/routes/forgot-password.tsx ...
[703/730] Analyzing frontend/src/routes/index.tsx ...
[704/730] Analyzing frontend/src/routes/login.tsx ...
Compacting rolling context after 704 file(s) ...
[705/730] Analyzing frontend/src/routes/register.tsx ...
[706/730] Analyzing frontend/src/routes/reset-password.tsx ...
[707/730] Analyzing frontend/src/routes/users/$userId/pair.error.tsx ...
[708/730] Analyzing frontend/src/routes/users/$userId/pair.index.tsx ...
[709/730] Analyzing frontend/src/routes/users/$userId/pair.success.tsx ...
[710/730] Analyzing frontend/src/routes/users/$userId/pair.tsx ...
[711/730] Analyzing frontend/src/routes/widget.connect.tsx ...
[712/730] Analyzing frontend/src/styles.css ...
Compacting rolling context after 712 file(s) ...
[713/730] Analyzing frontend/tailwind.config.ts ...
[714/730] Analyzing frontend/tsconfig.json ...
[715/730] Analyzing frontend/vite.config.ts ...
[716/730] Analyzing mcp/README.md ...
[717/730] Analyzing mcp/app/__init__.py ...
[718/730] Analyzing mcp/app/config.py ...
[719/730] Analyzing mcp/app/main.py ...
[720/730] Analyzing mcp/app/prompts.py ...
Compacting rolling context after 720 file(s) ...
[721/730] Analyzing mcp/app/services/_init_.py ...
[722/730] Analyzing mcp/app/services/api_client.py ...
[723/730] Analyzing mcp/app/tools/_init_.py ...
[724/730] Analyzing mcp/app/tools/activity.py ...
[725/730] Analyzing mcp/app/tools/sleep.py ...
[726/730] Analyzing mcp/app/tools/timeseries.py ...
[727/730] Analyzing mcp/app/tools/users.py ...
[728/730] Analyzing mcp/app/tools/workouts.py ...
[INFO] Gemini rate limit (HTTP 429/503); waiting 15s before retry 1 ...
Compacting rolling context after 728 file(s) ...
[INFO] Gemini rate limit (HTTP 429/503); waiting 15s before retry 1 ...
[729/730] Analyzing mcp/app/utills.py ...
[730/730] Analyzing mcp/pyproject.toml ...
Final context compaction ...
Synthesizing unified security report ...
Artifact tree written to './report.report-tree'
```

Demo · Report Output

```
report-tree/  
  files/      ← per-source reviews  
  compaction/ ← rolling summaries  
  synthesis/  
    final-report.md
```

Sections: Executive summary ·
Architecture · High attack-surface files ·
Themes · Review checklist.

Demo · Report Output (Datapipe)

--llm-report Pipeline

Phase 1 – Local index

RepositoryAnalyzer walk

Identify analyzable text files

Phase 2 – Per-file analysis

One LLM call per file (delimiter-wrapped)

→ report-tree/files/<path>.md

Phase 3 – Rolling compaction (every N=8 files)

Batches → rolling architecture summary

Binary split if context too large

→ report-tree/compaction/

Phase 4 – Final synthesis

Rolling summary + high attack-surface files

→ Executive summary

→ Architecture & trust boundaries

→ High attack-surface files

→ Themes & review checklist

Resilience Features

HTTP 500: up to 30 retries per request + 30 step-level retries

Oversized inputs: chunked inputs + merge

Compaction: hierarchical (sequential + by-directory)

Report Sections

1. Executive summary
2. Architecture and trust boundaries
3. High attack-surface files
4. Broader codebase themes
5. Recommended review checklist

DevOps & Engineering Process

Toolchain

Tool	Role
git + GitHub	Source control, PRs, issue board
uv (Astral)	Package manager, lockfile, build
GitHub Actions	CI/CD on push + PR to main
pytest	~80+ tests, mocked HTTP
bandit	Static security analysis
pip-audit	CVE scan on locked deps

CI Pipeline (`.github/workflows/ci.yml`)

```
checkout
↓
setup-uv
↓
uv sync --frozen --all-groups
↓
pytest
↓
bandit -r src/secanalyzer
↓
pip-audit
```

Green CI = tests + static security + dependency audit all pass.

Build: `uv build → wheel + sdist in dist/`

Documentation

File	Purpose
README.md	Install, CLI reference, troubleshooting
QUICKSTART.md	Step-by-step first run
SECURITY.md	Vuln reporting, data handling
docs/TECHNICAL_REPORT.md	Architecture deep dive
docs/SECURITY_REPORT.md	Threat ↔ code mapping
AGENTS.md	Phase checklist for maintainers

Limitations & Caveats

LLM output is advisory Not a formal security audit or compliance sign-off. Treat all AI text as a draft that requires human verification.

Prompt injection risk reduced, not eliminated Delimiter blocks and schema validation help; not cryptographic guarantees.

--llm-report can be expensive for massive codebases One API call per file + compactions + synthesis. Check token costs before running on large repos.

Gemma / Google free tier May return HTTP 500 or rate limits. Retries help but runs can be slow.

Incorrectly formatted outputs We may receive outputs that are pathological from the LLM (like the issue with the model repeating back the prompt)

Runs very slowly on big codebases It takes up to an hour on codebases with 10000+ lines of codes. Performance may also degrade due to context compaction on larger codebases.

Q&A

Questions?

github.com/flufcloud/366_project

Issue board: github.com/users/flufcloud/projects/2/views/1

[docs/TECHNICAL_REPORT.md](#) · [docs/SECURITY_REPORT.md](#) · [SECURITY.md](#)

Backup: Environment Variables & Troubleshooting

Variable	Effect
SECANALYZER_CONFIG_DIR	Override config directory (automated tests)
SECANALYZER_LLM_COMPACT_EVERY	Files between compaction passes (default 8)
SECANALYZER_LLM_ROLLING_MAX_TOKENS	Rolling summary token budget
SECANALYZER_LLM_BATCH_DELAY_SEC	Delay between LLM batch calls
SECANALYZER_LLM_SERVER_ERROR_MAX_RETRIES	HTTP 500 retry limit
SECANALYZER_GEMINI_MODEL	Override Google model id

Common issues:

- **Model 404:** check `--list-google-models` for available Gemini model ids; set via `SECANALYZER_GEMINI_MODEL`
- **HTTP 500 loops:** increase `SECANALYZER_LLM_SERVER_ERROR_MAX_RETRIES` ; Google free tier is rate-limited
- **WSL .venv mismatch:** run `uv sync --all-groups` inside WSL shell, not Windows CMD; use separate venvs
- `--issues` **menu not rendering:** requires interactive TTY; don't pipe stdin